Merge Status Code

PROM06 TC02 – Unrestricted SSH (INDEPENDENT rerun) #71

Open abdulwaheed384 wants to merge 1 commit into `main` from `indep-tc02`

Conversation 9 Commits 1 Checks 1 Files changed 1 +14

Reviewers

No reviews

Still in progress? Convert to draft

Assignees

No one—assign yourself

Labels

None yet

Projects

None yet

Milestone

No milestone

Development

Successfully merging this pull request may close these issues.

None yet

1 participant

abdulwaheed384 commented 4 hours ago Owner

PROM06 independent rerun of TC02 (Unrestricted SSH). Terraform is identical to the original test-case commit; the workflow runs Checkov, tfsec and the AI reviewer independently (post-PR #69, no scanner findings supplied to the AI). Research fixture only: do not merge, do not apply.

🤖 Generated with Claude Code

https://claude.ai/code/session_019GGG1f33Kz2g4dpPAJoY44

Generated by Claude Code

PROM06 Evidences Collection TC02 ··· Unverified ✓ 3eda6f7

github-actions Bot commented 4 hours ago

Checkov Security Scan

Experiment condition: INDEPENDENT
Version: 3.3.1
Scan status: COMPLETED_CLEAN
Passed: 7 · **Failed:** 0 · **Skipped:** 0

No failed checks were reported.

github-actions Bot commented 4 hours ago

tfsec Security Scan

Experiment condition: INDEPENDENT
Version: v1.28.14
Scan status: COMPLETED_WITH_FINDINGS
Findings: 2

Findings

- **CRITICAL · AVD-AZU-0047** — Security group rule allows ingress from public internet.; resource: `azurerm_network_security_group.nsg`; file: `/home/runner/work/ai-pr-review/ai-pr-review/terraform/nsg.tf`
- **CRITICAL · AVD-AZU-0050** — Security group rule allows ingress to SSH port from multiple public internet addresses.; resource: `azurerm_network_security_group.nsg`; file: `/home/runner/work/ai-pr-review/ai-pr-review/terraform/nsg.tf`

github-actions Bot commented 4 hours ago

AI Security Review

Experiment condition: INDEPENDENT
Automated operational score: 70/100 — MEDIUM — APPROVE_WITH_COMMENTS
This tool is for demonstration purposes only.

Summary

The AI reviewer reported 1 confirmed actionable finding(s).

Findings

- **HIGH · SECURITY_VULNERABILITY · Unrestricted inbound SSH access permitted from any source address**
  - Category rationale: The Terraform code directly configures an inbound NSG rule that allows TCP port 22 (SSH) from source 0.0.0.0/0 to any destination, exposing SSH to the entire internet. This is a concrete, demonstrable security weakness present in the changed file, independent of whether there is currently a VM listening on that port.
  - Evidence: azurerm_network_security_group.nsg, security_rule 'AllowSSH': priority=300, direction='Inbound', access='Allow', protocol='Tcp', source_port_range='', *destination_port_range='22', source_address_prefix='0.0.0.0/0', destination_address_prefix=''*.
  - Analysis: The NSG rule 'AllowSSH' at priority 300 permits inbound TCP traffic on port 22 from source address prefix '0.0.0.0/0' (any internet address) to any destination within the associated subnet. The rule is evaluated before the 'DenyAllInbound' rule at priority 4096, meaning any host on the internet can reach port 22 on resources in this subnet. The in-code comment 'TC02: Deliberately unrestricted SSH access' acknowledges the intent, but intentionality does not eliminate the security risk. SEC-001 prohibits public exposure unless explicitly required and justified; no justification is documented in the supplied policy or repository context.
  - Impact: Any internet-connected host can attempt SSH connections to resources deployed in the associated subnet (azurerm_subnet.subnet, 10.0.1.0/24). This exposes the environment to brute-force credential attacks, exploitation of SSH implementation vulnerabilities, and lateral movement if any host accepts connections. The outbound DenyAllOutbound rule limits exfiltration paths but does not mitigate the inbound exposure.
  - Recommendation: Restrict source_address_prefix to a known, trusted CIDR range (e.g., a corporate VPN or jump-host IP) or remove the rule if SSH access is not currently required. If SSH access is operationally necessary for research purposes, document the justified source range and update the rule accordingly. Do not use 0.0.0.0/0 as the source for administrative protocols.

Policy mappings

- **SEC-001** — No resource should be publicly exposed unless explicitly required and justified. (finding F-001)

Recommendation

Review and remediate the confirmed findings above.





github-actions Bot commented 3 hours ago

Checkov Security Scan

Experiment condition: INDEPENDENT
Version: 3.3.1
Scan status: COMPLETED_CLEAN
Passed: 7 · **Failed:** 0 · **Skipped:** 0

No failed checks were reported.





github-actions Bot commented 3 hours ago

tfsec Security Scan

Experiment condition: INDEPENDENT
Version: v1.28.14
Scan status: COMPLETED_WITH_FINDINGS
Findings: 2

Findings

- **CRITICAL · AVD-AZU-0047** — Security group rule allows ingress from public internet.; resource: `azurerm_network_security_group.nsg` ; file: `/home/runner/work/ai-pr-review/ai-pr-review/terraform/nsg.tf`
- **CRITICAL · AVD-AZU-0050** — Security group rule allows ingress to SSH port from multiple public internet addresses.; resource: `azurerm_network_security_group.nsg` ; file: `/home/runner/work/ai-pr-review/ai-pr-review/terraform/nsg.tf`





github-actions Bot commented 3 hours ago

AI Security Review

Experiment condition: INDEPENDENT
Automated operational score: 70/100 — MEDIUM — APPROVE_WITH_COMMENTS
This tool is for demonstration purposes only.

Summary

The AI reviewer reported 1 confirmed actionable finding(s).

Findings

- **HIGH · SECURITY_VULNERABILITY · Inbound SSH (port 22) permitted from any source address (0.0.0.0/0)**
  - Category rationale: The NSG rule 'AllowSSH' is concretely configured with source_address_prefix = '0.0.0.0/0' and destination_port_range = '22', permitting inbound SSH from any IP address on the internet. At priority 300 it is evaluated before the DenyAllInbound rule at priority 4096, making it fully effective regardless of the deny-all baseline. The code comment 'TC02: Deliberately unrestricted SSH access' acknowledges the rule but a documented label does not make the exposure safe or compliant with SEC-001.

- Evidence: azurerm_network_security_group.nsg, security_rule 'AllowSSH': priority = 300, direction = 'Inbound', access = 'Allow', protocol = 'Tcp', destination_port_range = '22', source_address_prefix = '0.0.0.0/0'. DenyAllInbound rule at priority = 4096 is evaluated after this rule.
- Analysis: The security_rule named 'AllowSSH' in azurerm_network_security_group.nsg allows TCP port 22 inbound from source 0.0.0.0/0 at priority 300. Because Azure evaluates NSG rules in ascending priority order, this rule takes effect before the DenyAllInbound rule at priority 4096. Any host on the public internet can attempt SSH connections to resources in the associated subnet (subnet-demo, 10.0.1.0/24). The code comment labels this as 'TC02: Deliberately unrestricted SSH access', confirming the rule is intentional, but does not supply a documented justification that satisfies SEC-001.
- Impact: Any internet-connected host can reach TCP port 22 on resources attached to this subnet. Exposed SSH services are subject to brute-force, credential-stuffing, and exploitation of SSH implementation vulnerabilities. Even in a research environment, a compromised host within the VNet could be used to pivot to other resources or exfiltrate data.
- Recommendation: Replace the unrestricted source_address_prefix '0.0.0.0/0' with a specific, justified CIDR range or a named Azure service tag (e.g., the operator's known egress IP range). If SSH access is not required for any resource in this subnet, remove the AllowSSH rule entirely. If the exposure is intentional for research purposes (TC02), supply explicit written justification, document the exception against SEC-001, and ensure no production-bound resource is attached to this subnet.

Policy mappings

- **SEC-001** — No resource should be publicly exposed unless explicitly required and justified. (finding F-001)

Recommendation

Review and remediate the confirmed findings above.





github-actions Bot commented 3 hours ago

Checkov Security Scan

Experiment condition: INDEPENDENT
Version: 3.3.1
Scan status: COMPLETED_CLEAN
Passed: 7 · **Failed:** 0 · **Skipped:** 0

No failed checks were reported.





github-actions Bot commented 3 hours ago

tfsec Security Scan

Experiment condition: INDEPENDENT
Version: v1.28.14
Scan status: COMPLETED_WITH_FINDINGS
Findings: 2

Findings

- **CRITICAL · AVD-AZU-0047** — Security group rule allows ingress from public internet.; resource: `azurerm_network_security_group.nsg`; file: `/home/runner/work/ai-pr-review/ai-pr-review/terraform/nsg.tf`
- **CRITICAL · AVD-AZU-0050** — Security group rule allows ingress to SSH port from multiple public internet addresses.; resource: `azurerm_network_security_group.nsg`; file: `/home/runner/work/ai-pr-review/ai-pr-review/terraform/nsg.tf`





github-actions Bot commented 3 hours ago

AI Security Review

Experiment condition: INDEPENDENT
Automated operational score: 70/100 — MEDIUM — APPROVE_WITH_COMMENTS
This tool is for demonstration purposes only.

Summary

The AI reviewer reported 1 confirmed actionable finding(s).

Findings

- **HIGH · SECURITY_VULNERABILITY · NSG permits inbound SSH (TCP/22) from any source (0.0.0.0/0)**
  - Category rationale: The NSG security_rule 'AllowSSH' explicitly permits inbound TCP port 22 from source_address_prefix '0.0.0.0/0' to any destination at priority 300, which is evaluated before the DenyAllInbound rule at priority 4096. This exposes SSH on any attached resource to the entire internet. The inline comment '# TC02: Deliberately unrestricted SSH access' acknowledges this is intentional for the test case, but it constitutes a concrete, demonstrable security weakness in the deployed configuration regardless of research intent.
  - Evidence: azurerm_network_security_group.nsg, security_rule 'AllowSSH': priority = 300, direction = 'Inbound', access = 'Allow', protocol = 'Tcp', destination_port_range = '22', source_address_prefix = '0.0.0.0/0'. The DenyAllInbound rule at priority 4096 does not block traffic matched by this earlier rule.
  - Analysis: The 'AllowSSH' security rule in azurerm_network_security_group.nsg grants inbound access on TCP port 22 from all IP addresses (source_address_prefix = '0.0.0.0/0') at priority 300. Because lower numeric priorities are evaluated first in Azure NSGs, this rule takes precedence over the 'DenyAllInbound' rule at priority 4096, meaning any host on the internet can attempt SSH connections to resources associated with this NSG. The TC02 comment documents this as deliberate, but the configuration still represents an unrestricted public exposure of a sensitive administrative port.
  - Impact: Any internet host can initiate TCP connections to port 22 on resources in subnet-demo (10.0.1.0/24) that are associated with nsg-demo-ai. If any VM or other SSH-capable resource is attached to this subnet, it is exposed to brute-force, credential stuffing, and exploitation of SSH vulnerabilities from the entire internet.
  - Recommendation: Restrict source_address_prefix to a known management IP range or a private CIDR (e.g., the VNet address space '10.0.0.0/16') rather than '0.0.0.0/0'. If internet-reachable SSH is required by the test case, document the compensating controls (e.g., key-only authentication, fail2ban, no VM currently attached) and set a planned expiry. Remove or restrict the rule when TC02 testing is complete. Per SEC-001, public exposure must be explicitly required and justified.

Policy mappings

- **SEC-001** — No resource should be publicly exposed unless explicitly required and justified. (finding F-001)

Recommendation

Review and remediate the confirmed findings above.

All checks have passed
2 successful checks

No conflicts with base branch
Merging can be performed automatically.

Merge pull request | You can also merge this with the command line. View command line instructions.

Still in progress? Convert to draft